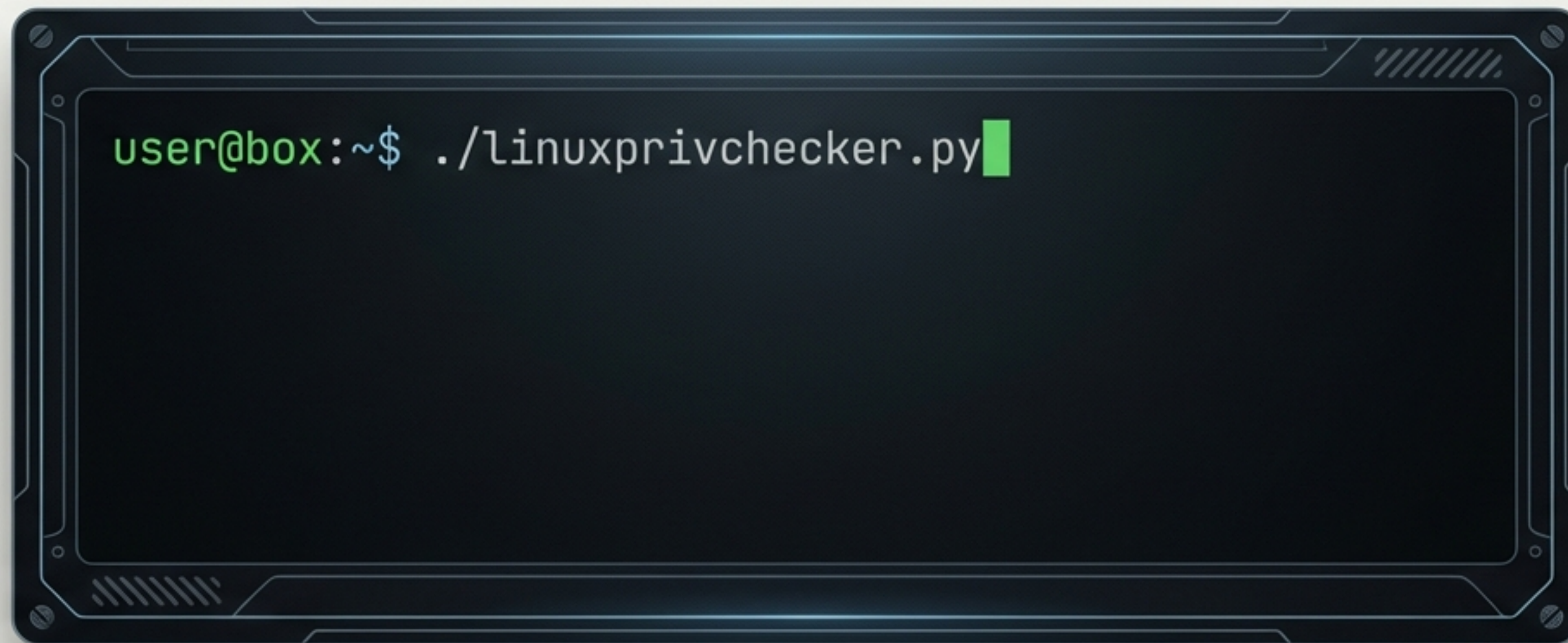
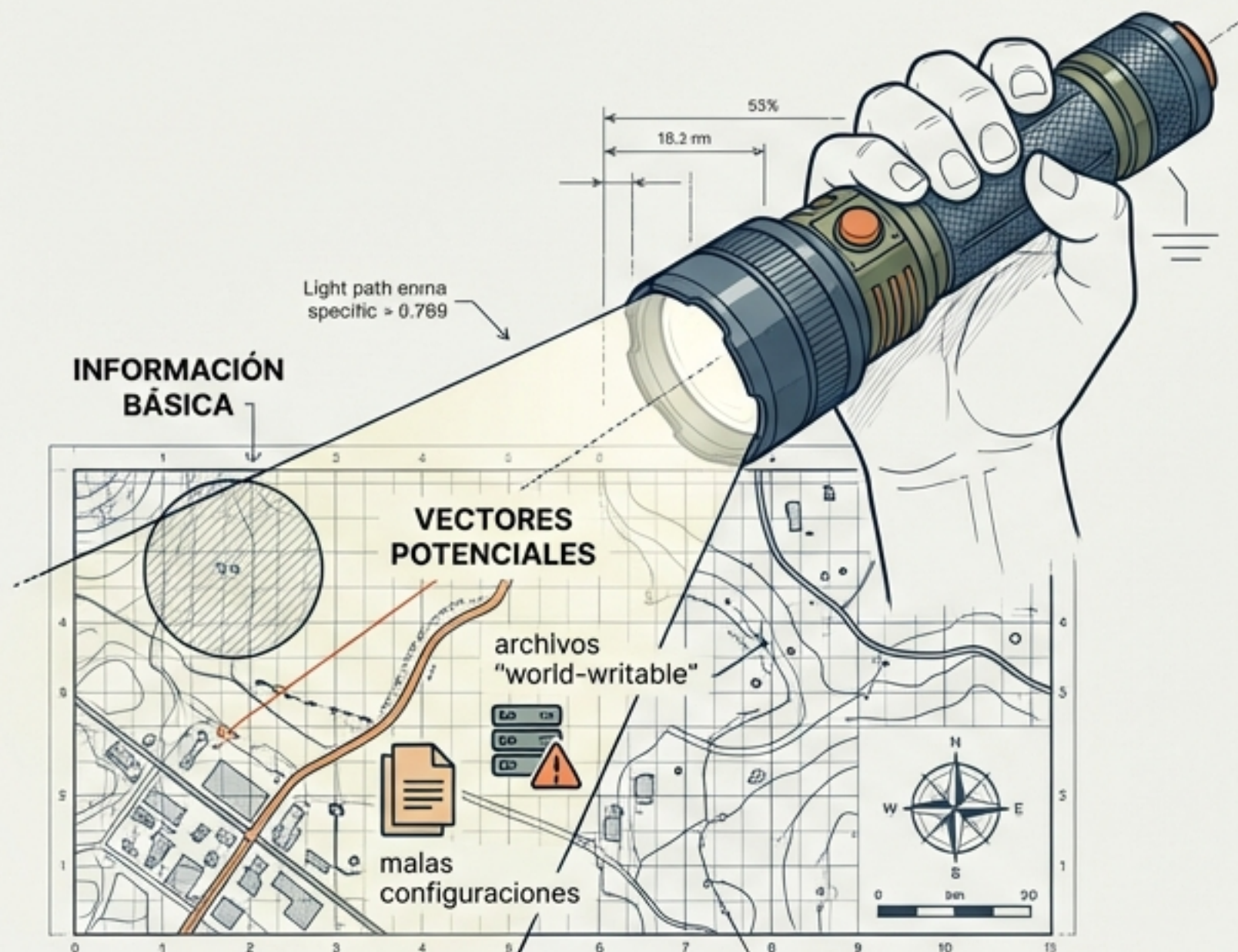




LINUXPRIVCHECKER.PY: MANUAL DE CAMPO

Auditoría, Enumeración y Escalada de Privilegios en Linux

EL ROL DEL ENUMERADOR

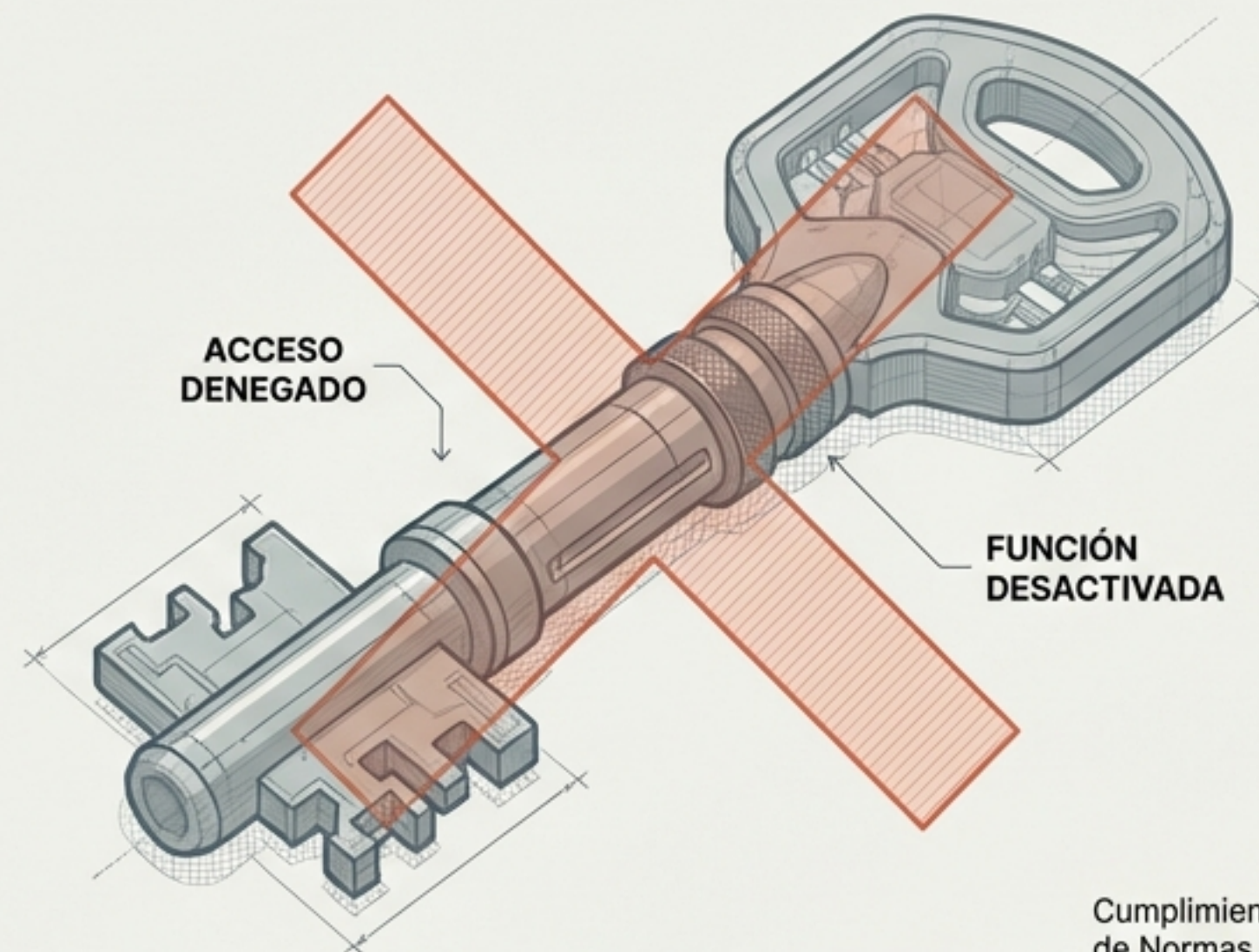


ENUMERACIÓN (Mapa)

Un script de verificación local diseñado para mapear el sistema. Identifica información básica y vectores potenciales (archivos "world-writable", malas configuraciones).

Verificación de alcance

Identificación de Activos



NO ES EXPLOTACIÓN (Llave)

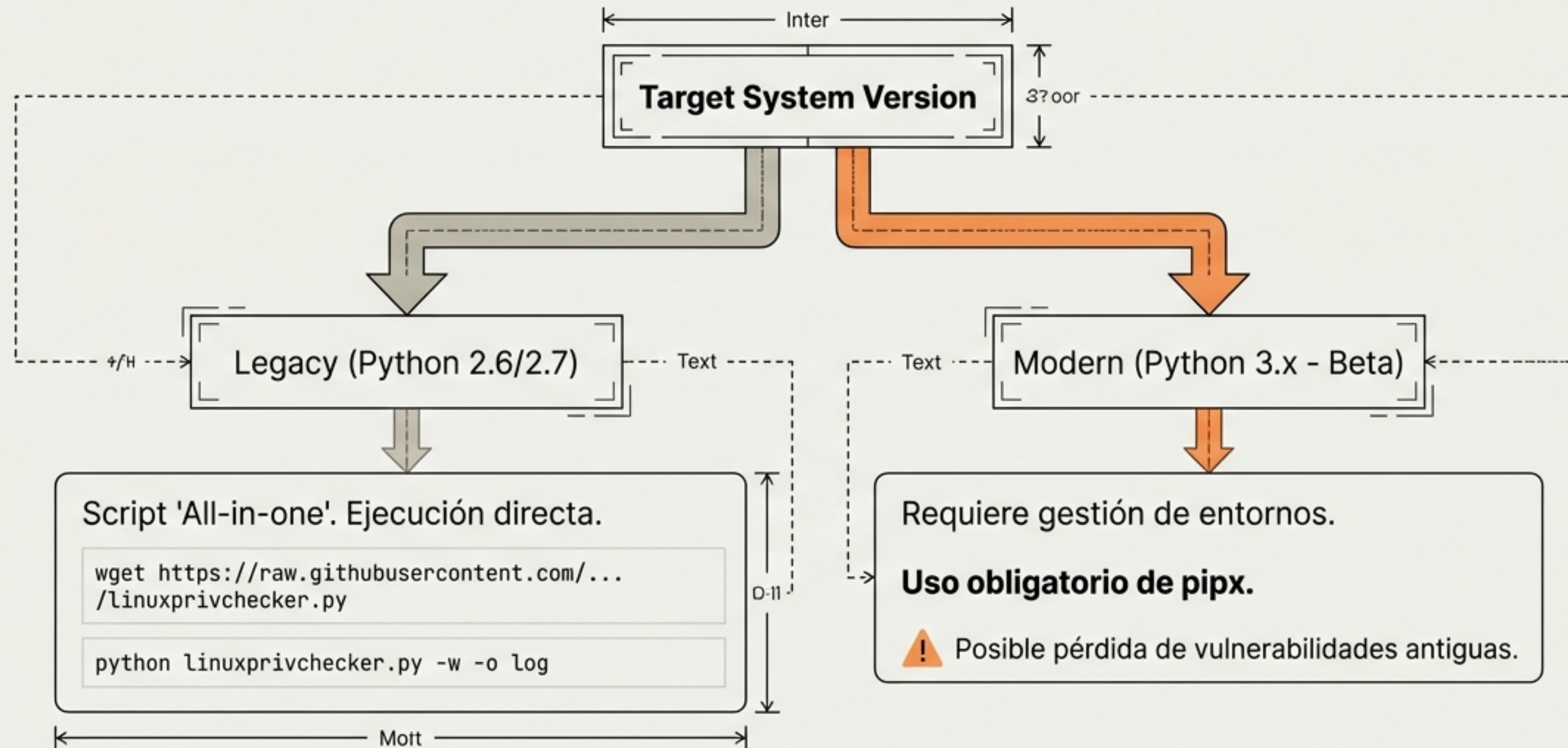
Diseñado para identificar áreas de investigación, no para realizar la acción directa (Auto-pwn). Ideal para aprender la metodología y cumple con reglas OSCP/CTF.

Cumplimiento de Normas



Reglas OSCP/CTF

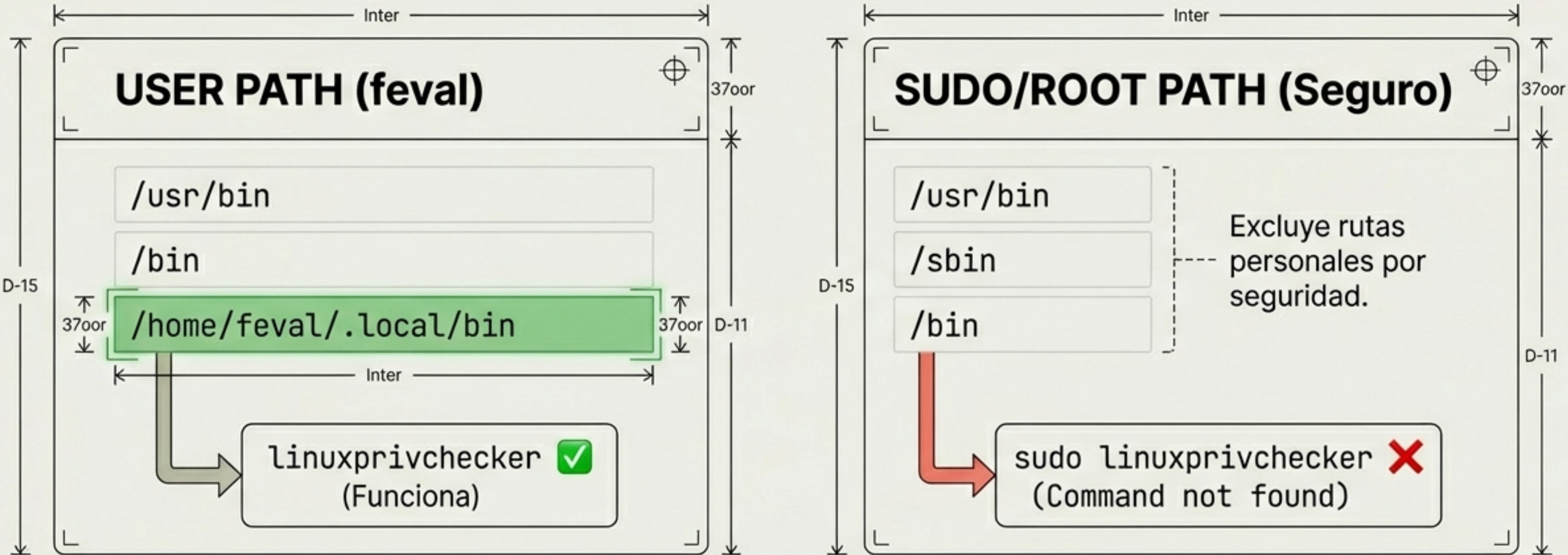
Estrategia de Entorno: Python 2 vs. Python 3



Flujo de Instalación con pipx



La Paradoja del PATH: Sudo vs. Usuario



Pipx instala en el directorio local del usuario. Sudo no mira ahí por defecto.

Ejecución Táctica y Forense

SOLUCIÓN: RUTA ABSOLUTA

> _



Para ejecutar como root usando una instalación de usuario, debemos ser explícitos:

```
sudo $HOME/.local/bin/linuxprivchecker
```

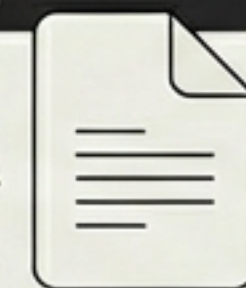
PRESERVACIÓN DE EVIDENCIA

> _



Fundamental para documentación y análisis forense pausado.

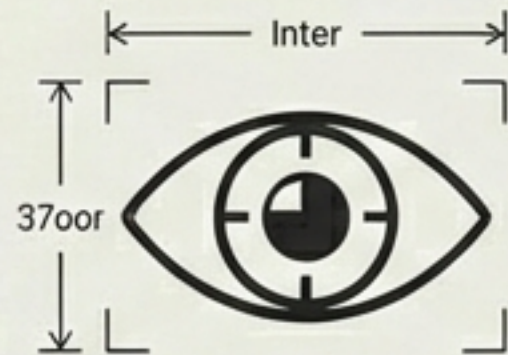
```
sudo $HOME/.local/bin/linuxprivchecker  
> /tmp/reporte.txt
```



reporte.txt

37oor

Modos de Operación



```
sudo $HOME/.local/bin/linuxprivchecker
```

Modo Estándar (Recomendado).

Escaneo completo. Acceso a archivos protegidos y visión total del sistema.



```
linuxprivchecker
```

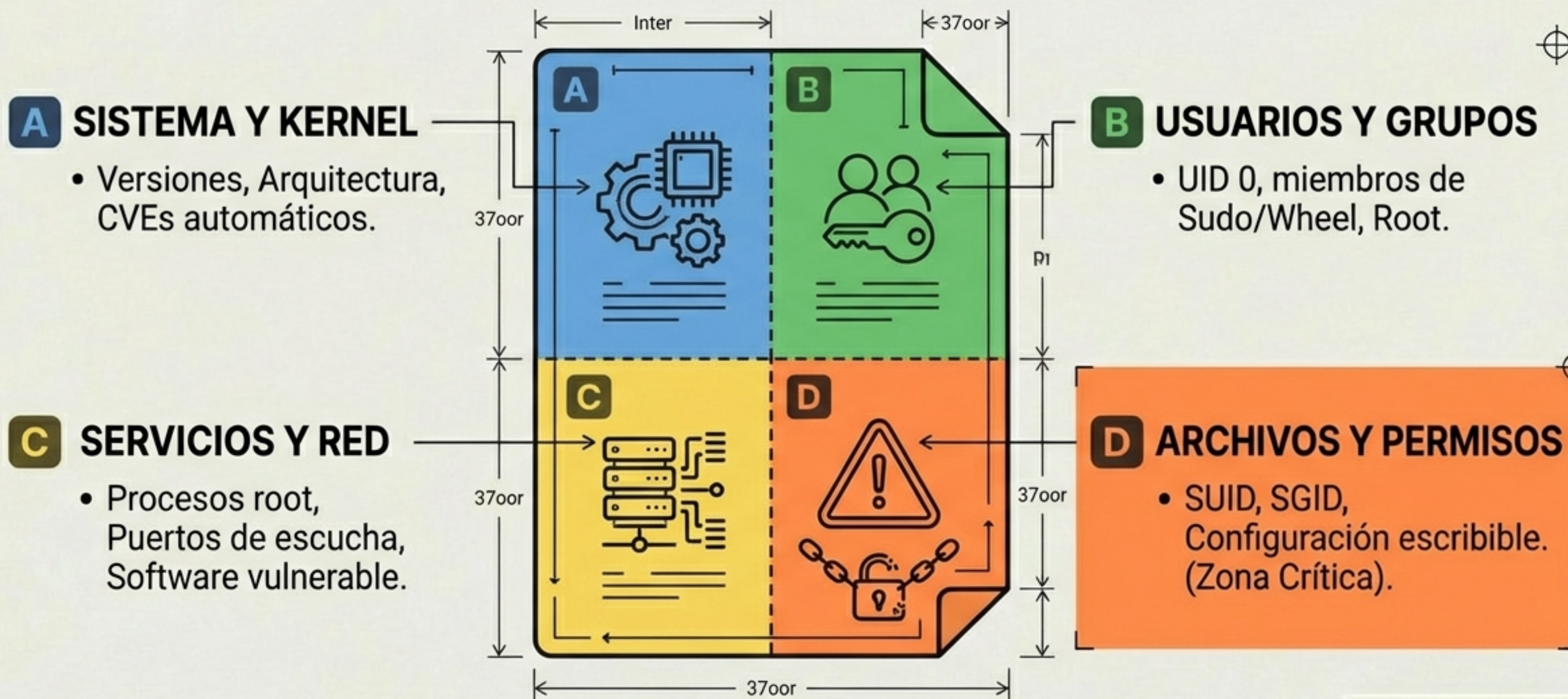
Modo Simulación (Usuario). Visión limitada. Simula lo que ve un atacante sin privilegios antes de escalar.



```
sudo python3 linuxprivchecker.py
```

Modo Depuración. Ejecución directa del script crudo si pipx falla.

Fase de Análisis: Anatomía del Reporte



Vector 1: Información del Kernel

```
[*] GETTING BASIC SYSTEM INFO...
```

```
Linux version 6.14.0-33-generic... Ubuntu 24.04.3 LTS
```



Qué buscar: Versión antigua o específica.

Interpretación: Si la herramienta marca un CVE, existe una ruta de 'Kernel Exploit'. El ataque no requiere configuración, sino un fallo en el código del sistema operativo.

Vector 2: Usuarios y Privilegios Sudo

 /etc/sudoers

```
root    ALL=(ALL:ALL) ALL
feval   ALL=(ALL:ALL) NOPASSWD: /usr/bin/vim
```

- Las Joyas de la Corona.
- **Qué buscar:** Usuarios con UID 0, grupos 'wheel' o 'sudo'.
- **Peligro Crítico (NOPASSWD):** Permite ejecutar binarios como root sin contraseña. Herramientas como vim, nmap o find permiten escapar fácilmente a una shell de root ('GTFOBins').

Vector 3: Archivos y Permisos (SUID)



Targets:

- Binarios SUID peligrosos (nmap, find, bash).
- Archivos de configuración escribibles (/etc/passwd, /etc/shadow).
- Scripts de cron modificables.

Caso de Estudio: El Usuario 'feval'

OBJETIVO: FEVAL

UID: 1000

Groups: feval, adm, cdrom,
dip, plugdev,
lpadmin,
sambashare, SUDO.

Veredicto: VULNERABILIDAD CRÍTICA.

El usuario pertenece al grupo administrativo. Si se obtiene la contraseña de usuario, el acceso a root es trivial. No se requiere exploit técnico, solo credenciales.

Caso de Estudio: Rastros en el Historial

.bash_history

Perfil LAMP Stack
+ WordPress
(Superficie de
ataque Web/DB)

```
sudo mysql_secure_installation  
sudo nano /etc/apache2/sites-available/wordpress.conf  
sudo nano wp-config.php  
find / -type d -perm 777
```

Intento activo de
escalada
(Busca carpetas 777).

wp-config.php suele contener
credenciales en texto plano.

Estrategia de Hardening (Defensa)



Kernel Update

Actualizar sistema si hay CVEs (apt upgrade).



SUID Cleanup

Remover bit SUID de binarios innecesarios (chmod u-s).



Permisos Estrictos

Restringir escritura en configs y cron (chmod 600).



Sudoers Hygiene

Eliminar directivas NOPASSWD y limitar comandos.

Conclusión: La Enumeración es la Clave



Linuxprivchecker automatiza la búsqueda, pero el analista **interpreta** los datos.

Utilice esta metodología para **auditoría y aprendizaje ético (OSCP/CTF)**.
Entender la inseguridad es el primer paso para blindar el sistema.